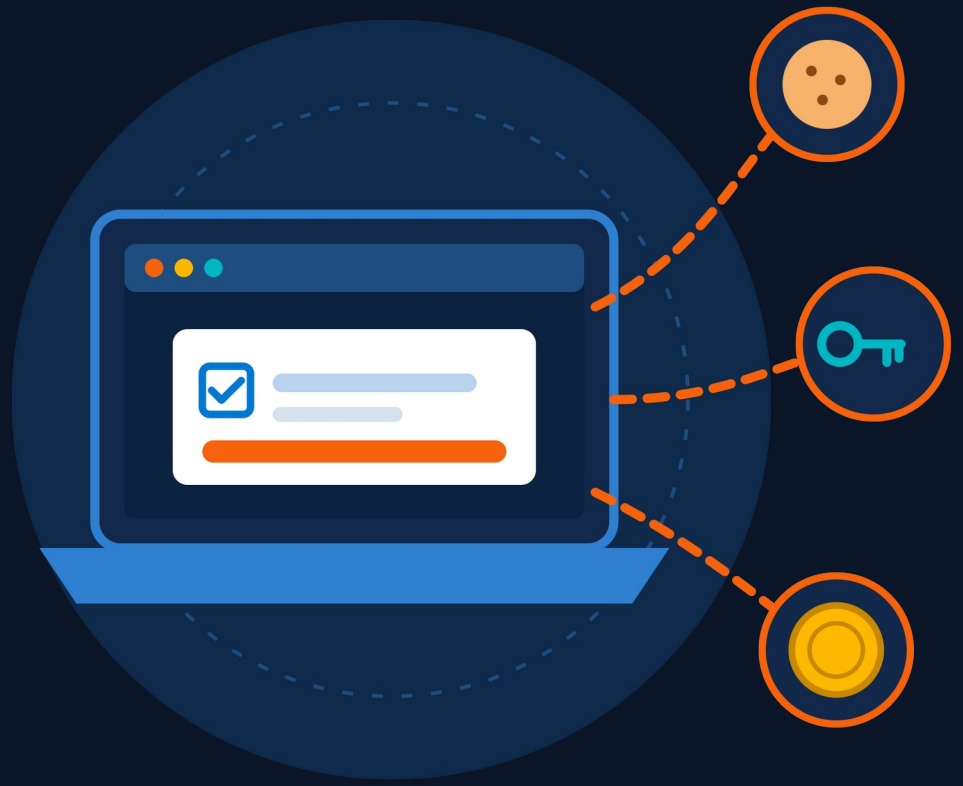
ZNEXORA TECH | THREAT BRIEFING

Lumma Stealer (LummaC2)

The information stealer behind fake CAPTCHA and ClickFix attacks



Presented by: **ZNexora Tech**

Information stealer | Malware-as-a-Service | Targets Windows

What is Lumma Stealer?

A leading information stealer that targets browser data, crypto wallets and session cookies, often distributed via fake CAPTCHA and ClickFix pages.

Malware-as-a-Service

Rented to criminal affiliates since 2022

Targets Windows PCs

Built to harvest data from Windows devices

Fast and evasive

Starts stealing as soon as it runs, then hides

TIMELINE

2022
First seen on criminal forums

2024
Widespread fake CAPTCHA and ClickFix campaigns

May 2025
Global takedown: about 2,300 domains seized

2025 – 2026
Back with new infrastructure and loaders

What Lumma steals

Browser data
Saved passwords, autofill and card details

Session cookies
Let attackers skip passwords and MFA



Crypto wallets
Wallet extensions, files and keys

2FA, apps and system info
Authenticator extensions and chat apps

WHY IT MATTERS Stolen data is bundled into “logs” and sold, fuelling account takeover and ransomware.

How Lumma reaches victims

Fake CAPTCHA pages
“Verify you’re human” tricks (ClickFix)

Malicious ads
Fake results at the top of search pages

Cracked software
“Free” versions of paid apps and tools

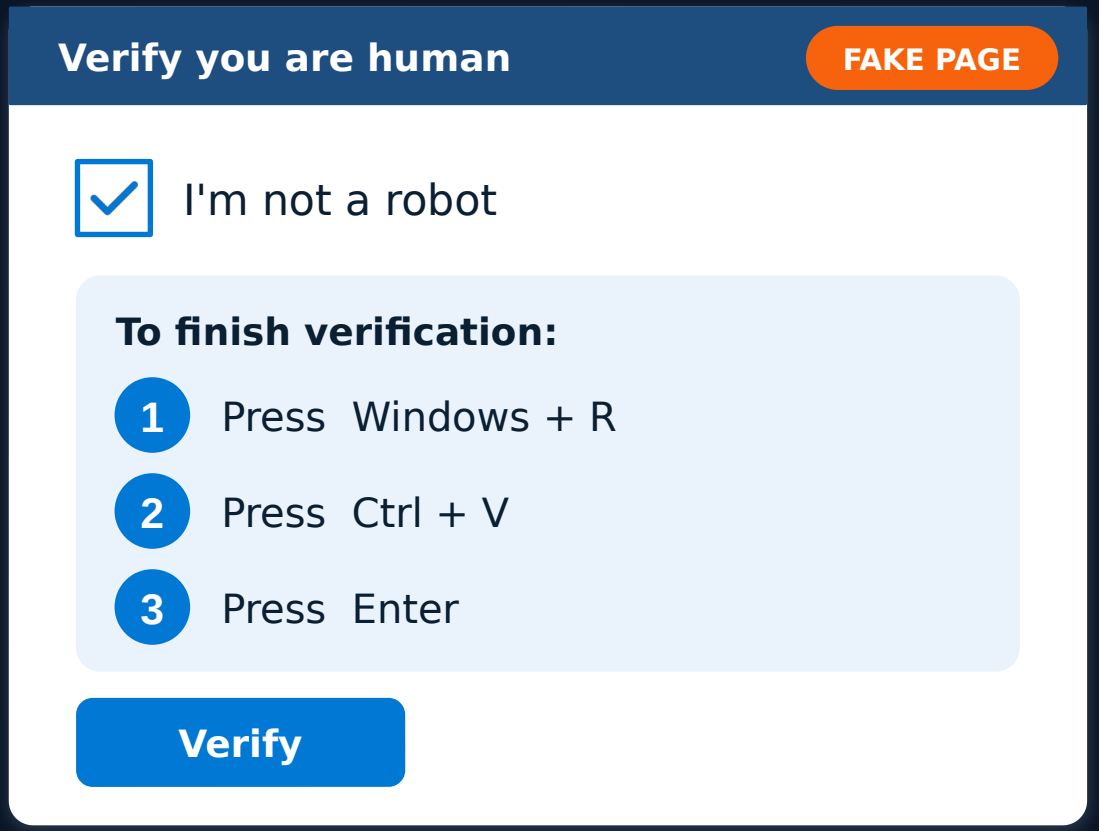
Game mods and cheats
Cheats and mods from unofficial sites

Phishing messages
Emails, chats and DMs with malicious links

Fake updates
Fake “browser out of date” pop-ups

COMMON THREAD You are tricked into running something yourself.

The fake CAPTCHA / ClickFix trick



1 The lure
A compromised site, malicious ad or fake download leads you to the page.

2 Fake verification
A “prove you’re human” box shows unusual keyboard steps.

3 Hidden command
The page has silently copied a malicious command to your clipboard.

4 You run it
Pasting and pressing Enter installs Lumma, which starts stealing.

A real CAPTCHA never asks you to open Run, paste or type commands.

From one paste to a breach

STEP 1
Lure
Fake page, ad or download

STEP 2
Execute
Victim runs the command

STEP 3
Steal
Passwords, cookies, wallets

STEP 4
Exfiltrate
Data sent to attackers

STEP 5
Sell
Logs sold on criminal markets

STEP 6
Exploit
Account takeover, fraud, ransomware

Steps 1 to 4
Happen on your device, often within minutes.

Steps 5 and 6
Other criminals, including ransomware groups, buy access.

Warning signs to watch for

WHAT YOU MIGHT NOTICE

- A web page asks you to press Windows + R or paste a command
- A command or PowerShell window flashes open
- Sudden logouts, or “new sign-in” alerts you don’t recognise
- MFA prompts or reset emails you didn’t request
- Missing crypto or unexpected account activity

WHAT IT AND SECURITY CAN DETECT

- PowerShell or mshta launched from the Run dialog
- New Run history (RunMRU) entries containing web commands
- Unusual processes reading browser password and cookie files
- Connections to newly registered or known Lumma domains
- Sign-ins from new locations reusing valid sessions

Six habits that stop Lumma

Never paste commands
No real website asks you to run anything.

Use official sources
No cracks or unofficial downloads.

Use a password manager
Don’t save passwords in the browser.

Use MFA and read alerts
Report prompts you didn’t expect.

Keep everything updated
Browser, Windows and security tools.

Keep crypto off work devices
Never store personal wallets at work.

If a page tells you to press Windows + R: close it and report it.

Layered controls for IT and security teams

Endpoint	EDR in block mode and ASR rules; restrict the Run dialog, PowerShell and mshta for standard users (GPO, AppLocker or WDAC).
Identity	Phishing-resistant MFA, Conditional Access for compliant devices, short session lifetimes and token protection.
Browser	Disable built-in password saving by policy, allowlist extensions and keep browsers patched.
Network	DNS and web filtering; block newly registered domains, malvertising and known Lumma infrastructure.
Monitoring	Threat-intel IOC feeds, alerts on suspicious PowerShell, and stealer-log monitoring for our domains.

Ran a suspicious command? Act fast

1. **Disconnect:** Unplug the network cable or turn off Wi-Fi.
2. **Report immediately:** Contact IT / Security on [contact].
3. **Reset from a clean device:** Change passwords and sign out of all sessions.
4. **Protect crypto funds:** Move funds to a new wallet; watch accounts.
5. **Let IT rebuild:** IT investigates and reimages the device.



WHY SPEED MATTERS

Every minute counts: stolen cookies work until sessions are revoked.

You will never be blamed for reporting.

Remediation playbook for IT

1

Contain

Isolate the device with EDR; block the attacker’s domains.

2

Scope

Review the timeline: what ran, what was stolen, which accounts.

3

Revoke

Reset passwords, revoke all sessions and tokens, rotate keys and secrets.

4

Eradicate

Reimage the device; don’t just delete files.

5

Recover

Monitor accounts and check for persistence or lateral movement.

6

Report and learn

Meet reporting duties, update blocklists, share lessons.

REMEMBER A password reset alone is not enough: stolen session cookies work until revoked.

Stop before you paste

- No real website asks you to run commands
- Cookies are keys: revoke sessions, not just passwords
- Layered controls stop one paste becoming a breach
- Report fast: minutes matter

Thank you